



PWN

Presented by Grissia



資安倫理宣傳

本課程所傳授之攻擊知識僅供教學使用，未經許可侵入他人電腦可能構成我國刑法第三十六章之妨害電腦使用罪，請學員不要以身試法

第三十六章 妨害電腦使用罪

- 第 358 條** 無故輸入他人帳號密碼、破解使用電腦之保護措施或利用電腦系統之漏洞，而入侵他人之電腦或其相關設備者，處三年以下有期徒刑、拘役或科或併科三十萬元以下罰金。
- 第 359 條** 無故取得、刪除或變更他人電腦或其相關設備之電磁紀錄，致生損害於公眾或他人者，處五年以下有期徒刑、拘役或科或併科六十萬元以下罰金。
- 第 360 條** 無故以電腦程式或其他電磁方式干擾他人電腦或其相關設備，致生損害於公眾或他人者，處三年以下有期徒刑、拘役或科或併科三十萬元以下罰金。
- 第 361 條** 對於公務機關之電腦或其相關設備犯前三條之罪者，加重其刑至二分之一。



OUTLINES

Dynamic Linking

PLT & GOT

Lazy Binding

ret2libc

DYNAMIC LINKING

- 在 runtime 才把 dll, so 載入到記憶體
- 節省硬碟、記憶體空間

LAZY BINDING

- Dynamic Linking 的一種機制
- 只載入會被呼叫的函式
- 節省記憶體空間

GLOBAL OFFSET TABLE

- 一個指標的陣列
- 存放已呼叫過的 `lib` 函式真實位址

PROCEDURE LINKAGE TABLE

- 一段可執行的程式碼
- 編譯時依照需要的函式填入
- 用來呼叫 GOT 和 `_dl_runtime_resolve`

LAZY BINDING

```
call puts@plt
```

- puts
- printf

PLT

```
call dlresolve
```

```
call puts@got
```

```
jmp plt
```

```
call printf@got
```

```
jmp plt
```

GOT

```
puts@plt+6
```

```
printf@plt+6
```


LAZY BINDING

```
call puts@plt
```

- puts
- printf

PLT

```
call dlresolve
```

```
call puts@got
```

```
jmp plt
```

```
call printf@got
```

```
jmp plt
```

GOT

REAL puts

```
printf@plt+6
```


GOT HIJACKING

- 因為 GOT 通常可寫
- 而且第二次執行就會直接走 GOT
- 所以我們可以竄改 GOT 來執行指定函式

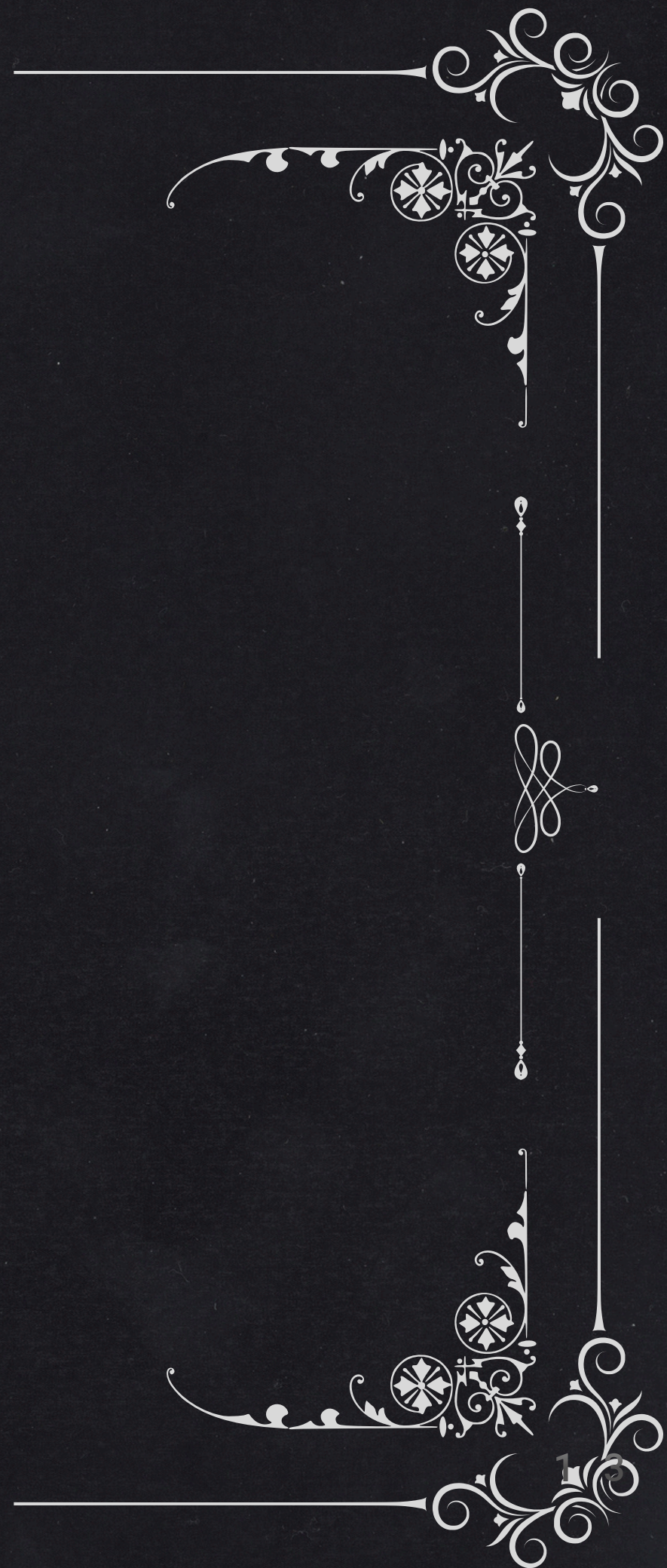
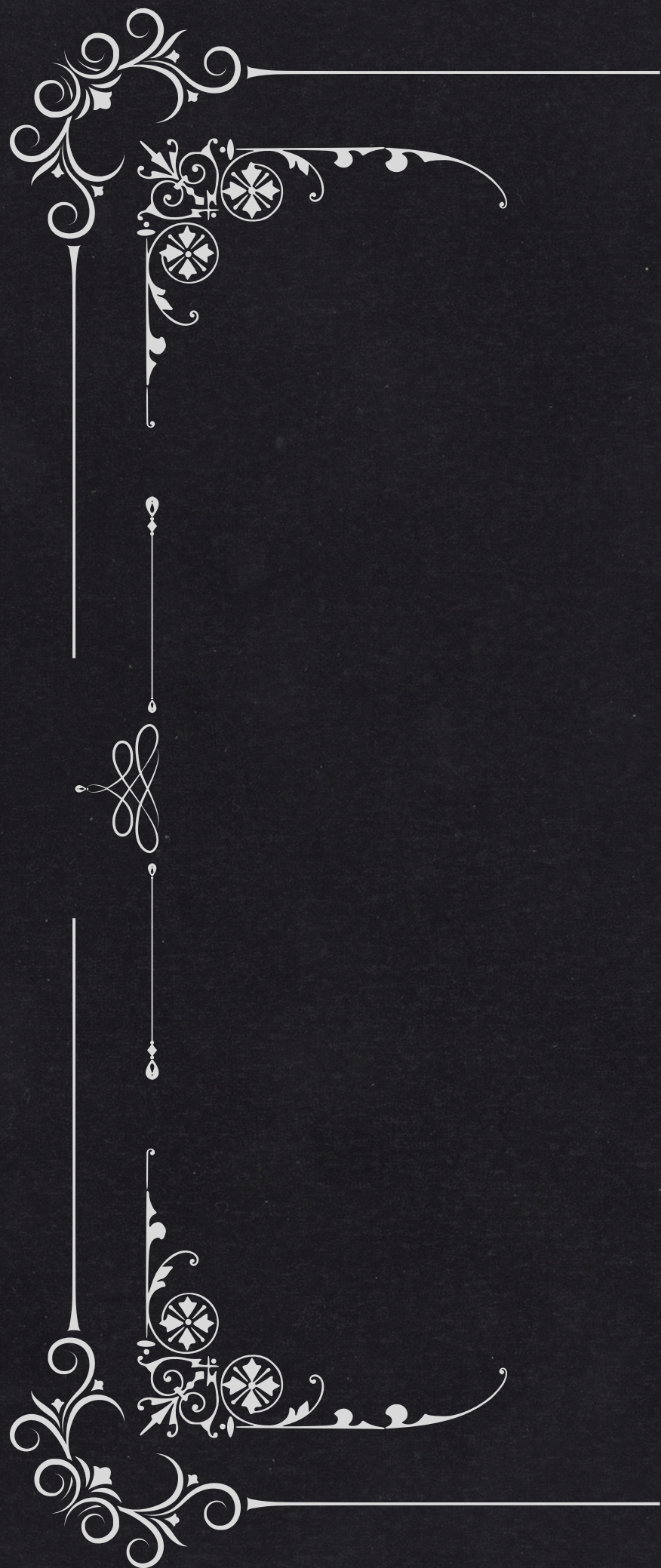
LAB - GOT HIJACKING

1. 把 `puts@got` 指向 `system`
2. 呼叫 `puts("sh")` 就會變成 `system("sh")`

Hint: 呼叫 `plt` 就相當於呼叫該函式

RET2LIBC

- lib 版的 ret2win
- 通常呼叫 `system("/bin/sh")`
- 需要 Bypass ASLR



:0

